

EU AI Act Article 14 — Human-Oversight Evidence Checklist

Version: EP-ART14-CHECKLIST-v1 · 2026-07 · public working document

What this document is. A mechanism-neutral checklist of the evidence questions a reviewer is likely to ask when assessing human oversight of a high-risk AI system under Article 14 of the EU AI Act, and properties that can make the resulting evidence more decision-useful — whatever tooling produced it. Section 4 shows how one specific implementation (an EMILIA Gate deployment) produces each item; that section is one candidate format, not a requirement of the checklist.

What this document is not. It is not legal advice, not an interpretation of the Act with legal effect, and not a compliance determination. It supports an assessment; it does not conclude one. Read the honesty block in Section 5 before citing anything here.

1. What Article 14 asks for, in plain terms

Article 14 of the EU AI Act addresses human oversight of high-risk AI systems. Rather than paraphrasing statutory text — deployers and their counsel should work from the Official Journal version — this checklist works from the duties the article names. Described by name, those duties are:

- Oversight by design.** High-risk AI systems are to be designed and developed so that natural persons can effectively oversee them while in use, including through appropriate human-machine interface tools.
- Risk-directed purpose.** Oversight exists to prevent or minimise risks to health, safety, and fundamental rights that can arise when the system is used as intended or under reasonably foreseeable misuse.
- Concrete oversight measures.** Oversight is delivered through measures either built into the system by the provider or identified by the provider for the deployer to implement — proportionate to the risks, the level of autonomy, and the context of use.
- Enabled overseers.** The natural persons assigned to oversight are to be enabled, as appropriate and proportionate, to:
 - understand the system’s relevant capacities and limitations, and monitor its operation;
 - remain aware of the tendency to over-rely on the system’s output (**automation bias**);
 - correctly interpret the system’s output;
 - decide not to use the system, or to **disregard, override, or reverse** its output;
 - intervene in the operation or interrupt the system** — for example through a stop control — so that it halts in a safe state.
- Heightened verification for certain uses.** For certain remote biometric identification uses, the Act imposes a stricter duty of separate verification by more than one natural person before action is taken on the system’s output. Deployers in that category should check the exact statutory conditions; this checklist treats it as the general pattern “some action classes need more than one human,” without restating the legal test.

Two consequences follow for evidence, regardless of tooling:

- A capability that was never exercisable is hard to evidence.** “A human could have intervened” is a design claim; a reviewer will look for the mechanism that made intervention possible *before the consequence*, and for at least one occasion on which it demonstrably operated.
- A record controlled solely by the party being assessed carries less weight.** Oversight records that the operator can silently edit after the fact answer the question “what does the operator say happened,” not “what happened.”

2. The checklist

For each oversight duty: the **evidence question** a reviewer may ask, and the **properties that make evidence more decision-useful** — independent of which product or process produces it.

2.1 “Show me who could intervene.”

Duty addressed: oversight measures exist and are assigned to natural persons.

Stronger evidence has these properties:

- ☐ **Named principal.** The overseer is an identified natural person (or an enumerable set of them), not a role name, a shared account, or “the operations team.”
- ☐ **Authority scoped to action class.** The record shows *which* classes of consequential action that person could authorize, refuse, or interrupt — not blanket authority.
- ☐ **Current at the time of the action.** Authority is tied to the moment of the decision: a person who had left the organisation, or whose authority was revoked, could not still appear as an effective overseer for later actions.
- ☐ **More-than-one-human where claimed.** Where the deployer claims a two-person (or M-of-N) rule, the evidence distinguishes *N distinct humans acted from one credential was used N times*.

Weak forms a reviewer will discount: an org chart; a policy document naming a role; an access list with no linkage to specific decisions.

2.2 “Show me an intervention that worked.”

Duty addressed: ability to intervene in operation or interrupt the system.

- ☐ **A recorded refusal or interruption**, with a stated reason, for a real (or realistic test) action — not only a description of the stop mechanism.
- ☐ **Pre-execution position.** The record shows the check sat *in the path of* the action: the action did not proceed until the check passed, and did not proceed at all when it failed. A log line written after the action completed does not have this property.
- ☐ **Fail-closed behaviour.** Evidence of what happens when the oversight mechanism itself is unavailable or cannot complete: does the consequential action proceed unrecorded, or stop? A mechanism that degrades to “proceed silently” undercuts the intervention claim.
- ☐ **Repeat and tamper attempts visible.** If an authorization can be captured and replayed, or altered in flight, the intervention capability is weaker than it appears; evidence should show such attempts being detected and refused, or explain why they are out of scope.

Weak forms: a screenshot of a “cancel” button; an incident-response runbook with no record of execution; approval logs that contain only approvals.

2.3 “Show me the approval was for *this* action, not an action like it.”

Duty addressed: overseers can correctly interpret output and decide on the specific operation.

- ☐ **Pre-execution binding to exact parameters.** The human’s authorization is bound to the specific action — amount, target, resource identifier — not to a category (“payments”) or a session (“whatever the agent does next hour”).
- ☐ **Substitution detectable.** If what executed differs from what was authorized, the evidence makes that divergence visible (ideally: the divergent execution was refused).
- ☐ **What the human saw is reconstructable.** Where the claim is “a human reviewed and approved this,” the strongest evidence lets a reviewer re-derive what was displayed to that human from the authorized data itself, so that a surface showing one thing while the system signed another is detectable. Few mechanisms in the field have this property today; where absent, that gap should be stated rather than papered over.

2.4 “Show me oversight is exercised, not performed.”

Duty addressed: awareness of automation bias; the ability to disregard, override, or reverse.

- ☐ **Refusals recorded as first-class events.** A record containing only approvals is consistent with rubber-stamping; refusals, with reasons, are the direct evidence that overseers exercise the disregard/override capability.

- ❑ **Refusal reasons are specific.** “Denied” is weaker than “denied because the assurance level was below what this action class requires” — a named failing condition shows the mechanism evaluated something.
- ❑ **The base rate is visible.** How many consequential decisions occurred in the period, and how many passed through oversight at all. A 100% approval rate over thousands of actions is a finding a reviewer will probe, not a reassurance.

2.5 “Show me the record survives the operator.”

Cross-cutting: every duty above is only as strong as the record of it.

- ❑ **Tamper-evidence.** Alteration or deletion of any oversight record after the fact is detectable — for example, because records are hash-chained or anchored so that removing one breaks verification of the rest.
- ❑ **Independent verifiability.** A third party — auditor, market-surveillance authority, insurer — can check the record’s integrity and the validity of the authorizations in it using published formats, their own tooling, and explicit pinned trust inputs. Offline verifiability (no callback to the operator or vendor at verification time) is the strong form of this property.
- ❑ **Cryptographic rather than procedural identity for approvals.** “This principal authorized this action” is stronger when it rests on a signature verifiable against a key attributable to that principal than when it rests on a database row asserting it.
- ❑ **Survivability stated honestly.** What happens to the record if the operator, or the oversight vendor, disappears? Evidence that can only be interpreted by the party that produced it has limited standing.

2.6 “Show me what the mechanism does NOT cover.”

Cross-cutting: scope honesty.

- ❑ **Measured coverage.** Of the consequential actions the system took in the period, what fraction passed through the oversight mechanism? A mechanism covering three action types out of thirty is evidence about those three.
- ❑ **Exceptions enumerated, not aggregated away.** Actions that bypassed oversight — out-of- band paths, unguarded action types, break-glass events — appear in the record as named exceptions the reviewer can count.
- ❑ **Empty is not perfect.** A period with no recorded decisions is indeterminate, and the evidence format should say so rather than render it as flawless coverage.
- ❑ **Malformed or unclassifiable records surfaced.** Records the reporting layer could not verify are listed, not silently dropped — a report that can quietly understate its own source data is weaker evidence than one that structurally cannot.

3. Evidence properties, in one line each

PROPERTY	ONE-LINE TEST
Named principal	Can you point to the natural person, and were they authorized <i>at that moment</i> ?
Pre-execution binding	Was the approval bound to the exact action, before it executed — and would drift have been refused?
Refusals recorded	Do denials appear in the record with named reasons, as first-class events?
Tamper-evidence	Would edit or deletion of any record after the fact be detectable?
Independent verifiability	Can a third party check it with its own tooling and pinned trust inputs, offline, without calling the operator?
Scope honesty	Does the evidence itself show what was <i>not</i> covered?

4. One implementation: how an EMILIA Gate deployment produces each item

This section describes one candidate format — the EP-GATE-ART14-PACK-v1 evidence pack emitted by the open-source EMILIA Gate (packages/gate/reports/art14.js in the EMILIA Protocol repository, Apache-2.0). It is included so the checklist above is falsifiable against at least one running mechanism, not to suggest it is the only way to support an assessment.

The Gate is a deny-by-default enforcement point: a guarded consequential action executes only with a valid, in-scope, sufficiently assured, fresh, unused authorization receipt signed over the exact action; otherwise it is refused with a machine-readable challenge, and every decision — allow or deny — is appended to a hash-chained, tamper-evident evidence log. The Article 14 pack is a pure function over that log for a stated reporting period.

CHECKLIST ITEM	PACK FIELD / MECHANISM	NOTES
2.1 Who could intervene	<code>oversight_exercised</code> rows: <code>principal × action_type × assurance_tier × count</code>	The credited assurance tier is cryptographically verified, not read from a self-asserted field: <code>class_a</code> requires a valid WebAuthn device signoff; <code>quorum</code> requires M distinct keys with per-signer assertions (the cryptographic two-person rule). Principal identity is <i>as pinned by the deployer</i> — mapping keys to real humans is the deployer's roster discipline, and a signer-roster sync from the deployer's IdP revokes a deprovisioned employee's keys on the next sync.
2.2 An intervention that worked	<code>interventions.entries</code> — each refusal with timestamp, action, principal, reason, and a named <code>failing_predicate</code> ; totals in <code>interventions.by_predicate</code>	The Gate sits pre-execution and fails closed: in strict mode, if the evidence log write fails, the action is refused rather than executed unrecorded (<code>evidence_log_failed</code>). Replayed receipts and receipts whose bound fields do not match the observed execution are refused and counted in <code>replay_tamper</code> .
2.3 Approval bound to <i>this</i> action	Exact-action receipt scope + execution-field binding	A receipt is in-scope only for the exact action it names; declared execution fields (e.g. <code>commit_sha</code> , <code>account</code> , <code>amount</code>) must match the authorized claim or the action is refused. Only fields the deployer declares are bound — an undeclared material field is unbound by construction, and that is a deployer manifest decision.
2.3 What the human saw	Not in the pack	A separate presentation-binding mechanism (deterministic re-derivable rendering + signed display attestation) exists in the same repository; it narrows the what-you-see-is-what-you-sign problem, it does not solve it. The pack itself makes no claim about what any overseer perceived.
2.4 Exercised, not performed	<code>interventions.total</code> , <code>interventions.by_predicate</code> , plus the allow-side tables	Refusals are first-class records with named failing predicates; an unmapped refusal reason surfaces as <code>unmapped:<reason></code> , visible rather than genericized away.
2.5 Record survives the operator	Hash-chained evidence log; <code>evidence.head</code> ties the pack to a specific chain state	Removing or altering any record breaks the chain and verification catches it. Receipts, signoffs, and quorums verify offline against published schemas. The chain proves integrity of what was recorded, never completeness of what the deployer chose to route through the Gate — and never the business correctness of any authorized action.

CHECKLIST ITEM	PACK FIELD / MECHANISM	NOTES
2.6 Coverage and exceptions	<code>coverage_ratio</code> (<code>decisions_guarded / decisions_total</code> ; <code>null</code> , not 1.0, for an empty period), <code>uncontrolled_action_exceptions</code> (each action that passed outside the manifest, listed individually), <code>integrity_warnings</code> (every log entry the pack could not classify, excluded from the tables and itemised)	The pack is deterministic: same log entries and options produce identical output, so a third party holding the log export can recompute it.
Scope honesty of the report itself	Mandatory honesty notice (notice)	The notice — stating that the pack <i>supports</i> an Article 14 assessment and is not compliance or a certification — is a structural part of the format: the renderer refuses to render a pack whose notice was altered or removed.

Status framing for anyone citing this implementation:

- The verification code paths exist in **JavaScript, Python, and Go in one repository — a consistency check, not independent implementations. Separately, an externally authored Rust implementation is rebuilt from a pinned public source tree and passes the pinned 16-suite/164-vector clean-room bundle plus 359 hostile cases. Strict clean-room construction acceptance remains zero pending independent attestation.**
- The underlying formats are described in **active INDIVIDUAL Internet-Drafts — not IETF-adopted or endorsed.**
- Formal models (TLA+, Alloy) cover the **core state machine and quorum logic only — not the WebAuthn binding and not transparency-log checkpoints.**
- Verification proves **signature, binding, and log integrity — never that the authorized action was the right business decision.**

5. Honesty block

Read this before citing this document anywhere.

- **This checklist supports an Article 14 assessment. It does not perform one.** Whether a given high-risk AI system's oversight measures are appropriate and proportionate is a judgment for the provider, the deployer, their counsel, and where applicable the notified body and market-surveillance authority — not for this document or any evidence format named in it.
- **Nothing here is legal advice**, and nothing here restates the Act with legal effect. Where this document and the Official Journal text of the EU AI Act differ, the Act governs; duties are described here by name precisely to avoid citing subsection structure this document should not be relied on for.
- **No evidence pack constitutes compliance.** Producing every artifact in Section 2 — by any mechanism, including the one in Section 4 — demonstrates properties of an oversight mechanism's operation over a period. It does not establish that oversight was adequate, that overseers were competent, or that the system's risks were in fact minimised.
- **EMILIA Protocol is not an auditor, a regulator, or an insurer.** Its documents and artifacts are inputs to assessments performed by those parties; they support conclusions, they never draw them.
- **Identity is as pinned by the deployer.** Cryptographic evidence attributes actions to keys; binding keys to natural persons, and keeping that binding current, is the deploying organisation's identity and HR process, which no receipt format replaces.
- **Coverage is bounded by routing.** Any enforcement-point mechanism evidences only the actions routed through it. The honest response to that boundary is to measure and disclose it (Section 2.6), not to imply totality.

Feedback on this checklist — including from reviewers who would ask different questions — is welcome via the EMILIA Protocol repository.